

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	Make 2-3 notes of specific business requirements that will be analyzed. • <i>Will the app process transactions?</i> ○ Yes, the app must securely and efficiently process payment transactions for buyers and sellers of products. • <i>Does it do a lot of back-end processing?</i> ○ Yes, many back-end requests will likely be made to the application for purposes such as storing login credentials, processing transactions, and managing vendor ratings. • <i>Are there industry regulations that need to be considered?</i> ○ Yes, in particular the PCI DSS (Payment Card Industry Data Security Standard), as customer payment information is a critical liability for the company. Additionally, encryption methods such as AES or SHA-256 should be implemented for secure communications via the application.
II. Define the technical scope	List of technologies used by the application: • <i>Application programming interface (API)</i> • <i>Public key infrastructure (PKI)</i> • <i>SHA-256</i> • <i>SQL</i> Write 2-3 sentences (40-60 words) that describe why you choose to prioritize that technology over the others. We have decided that these technologies are the first priorities for the companies' security posture because they are responsible for the majority of the application's services. It is imperative that the application guards against common attacks such as SQL injection and cross-site scripting. In addition, all communications should be encrypted and secure to reduce the likelihood of information being compromised.

III. Decompose application	Sample data flow diagram
IV. Threat analysis	List 2 types of threats in the PASTA worksheet that are risks to the information being handled by the application. • <i>What are the internal threats?</i> ◦ Internal threats include improper security training of employees or disgruntled employees who have access or insight into the internal network. • <i>What are the external threats?</i> ◦ External threats include malicious actors, malware in various forms, and automated (botnet) attacks. Each poses a unique risk to the companies' data.
V. Vulnerability analysis	List 2 vulnerabilities in the PASTA worksheet that could be exploited. • <i>Could there be things wrong with the codebase?</i> ◦ Yes, the codebase may be vulnerable to SQL injection or XSS attacks if user inputs are not sanitized and validated. • <i>Could there be weaknesses in the database?</i> ◦ Yes the database may be prone to a data leak if critical information is not encrypted and/or hashed if examining login credentials. Care should be taken to ensure that only authorized individuals have permission to alter the database. • <i>Could there be flaws in the network?</i> ◦ Yes, the network could have flaws in how it filters traffic, certifies legitimate users, and guards against network attacks.
VI. Attack modeling	Sample attack tree diagram
VII. Risk analysis and impact	List 4 security controls that you've learned about that can reduce risk. 1. User input sanitation + validation, and strong password requirements 2. Data encryption standards 3. Intrusion detection systems (IDS) 4. Firewalls and proper internal network configuration
